RECON + ENUMERATION | Evidence to the next decision

Companion to the Quicksheet / Worksheet • reference, not a second capture form • use only the branches relevant to the lab objective

COMMAND / PATTERN	WHAT / WHEN / CHECK
01 SCOPE / BASELINE / DISCOVERY	
`Record target, hostname, objective, time, role and evidence folder before starting.`	Define success; findings need not end in root or a shell.
`ip route get <IP>` `nmap --top-ports 1000 <IP> -oA first`	Route + initial TCP scan. No ping reply is not proof of down.
`nmap -p- <IP> -oA tcp-all` `nmap -sV -p <PORTS> <IP> -oA services`	Broaden when useful; verify actual service evidence.
`sudo nmap -sU -sV -p <UDP-PORTS> \` `  <IP> -oA udp`	UDP needs selection; open|filtered is inconclusive.
`nmap -sC -sV -p <PORTS> <IP> -oA scripts`	-sC adds default script probes. -Pn skips host discovery.
02 SERVICE -> QUESTION -> TOOL	

`HTTP/S -> correct app, routes, identity?`
`SMB -> service and permitted shares?`
`DNS -> names and records?`
`SSH/FTP -> implementation and access policy?`
	Identify service first. Port 445 alone is not Windows.

`curl -i http://<LAB-HOST>/` `curl -i http://<LAB-HOST>/missing-check-28`	Compare status, redirect, body/length; hostname matters.
`gobuster dir -u http://<LAB-HOST>/ \` `  -w <WORDLIST> -o paths.txt`	Validate soft 404s before filters; keep 401/403 leads.
`gobuster vhost -u http://<LAB-HOST>/ \` `  -w <WORDLIST> --append-domain`	Host-header discovery != DNS; base name must resolve.
`nxc smb <IP> -u '' -p '' --shares` `dig <HOST> A`	Null-session failure does not rule out valid-account access.

COMMAND / PATTERN	WHAT / WHEN / CHECK
03 MANUAL VALIDATION BEFORE A FINDING	
`Browse -> capture normal request -> change one input -> compare -> reproduce`	Retain identity; compare response and application state.
`XSS: marker -> exact browser context -> harmless execution -> affected role`	Reflection != execution. Inspect response AND DOM.
`IDOR: own object + second lab account -> change object ID -> compare access`	Test with lab accounts; 200 alone is not an access proof.
`CVE lead: product + affected version/config + reachable function + prerequisites`	Match actual conditions; banner/CVE label is only a lead.
04 AFTER ACCESS — RESTART WITH IDENTITY	
`Linux: id; sudo -l; ps aux; ss -tuln` `Windows: whoami /all; Get-Service`	Orient inside the host before choosing a privilege lead.
`Privileged consumer -> controlled input -> trigger -> observed effect`	SUID/writable path/token is one link, not the whole chain.
`Internal listener or credential artefact? Identify scope, type and needed prerequisite.`	Identify material/scope before authentication or pivoting.
05 FILTER / STOP / REPORT	
`RAW -> SELECT -> EXTRACT -> VERIFY` `Check retained AND excluded examples.`	Keep raw output + exact filter; inspect excluded rows too.
`Observed -> inferred -> next check -> result` `Supported / ruled out / inconclusive / prerequisite`	Log on Quicksheet. Blocked is not automatically a dead end.
`Record request/command, role, versions, expected/actual result, impact and fix.`	Reproducible proof; separate prompting from unaided work.
`STOP: question answered, evidence contradicts lead, scope ends, or prerequisite missing.`	Record stopping point and cleanup; promote one learning gap.

Pathway: CPSA recognition -> CRT/PEN-200/OSCP methodology; Security+ impact/controls. Learn -> Observe -> Practice -> Reinforce -> unfamiliar Checkpoint.